

SIMATS ENGINEERING

ASSESSMENT TOOL 3

COURSE CODE: CSA51 **COURSE NAME:** Cryptography and Network Security

COURSE OUTCOME COVERED

CO4: *Implement best security practices for IP, email, and web service using PGP, S/MIME for enhancing email Security.CO (BL3, BL6)*

Assessment Tool Weightage: 10%

QUESTIONS: 5

TOTAL MARKS: 25

Annexure A

Comparative Analysis

Code of Conduct:

*I RITHISH KUMAR D / 192565089 (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.
I understand that any violation of academic integrity rules will result in disciplinary action.*

Signature of the student: RITHISH KUMAR D

Department: CSE-CS

Date: 17-08-2026

ANSWER SHEET - ASSESSMENT TOOL 3

Comparative Analysis | CSA51 - Cryptography and Network Security

Q1. AH vs. ESP - Which Provides Better Security?

Aspect	AH	ESP
Confidentiality	No	Yes (encryption)
Integrity & authentication	Yes (whole IP packet incl. header)	Yes (payload; header optional)
Anti-replay protection	Yes	Yes
NAT traversal	Poor (breaks with NAT since it authenticates the whole packet)	Good (with NAT-T/UDP encapsulation)
Typical use case	Integrity-only compliance links	General-purpose VPN / secure tunnels

Verdict: For a general enterprise network scenario, **ESP provides the better overall security implementation** because it delivers confidentiality, integrity, authentication, and anti-replay protection together, and it works cleanly through NAT devices via NAT-Traversal, which AH cannot do (AH authenticates the outer IP header, so any NAT-induced address rewrite invalidates the ICV). AH remains preferable only in the narrow case where encryption is legally restricted or unnecessary but header-level integrity must still be guaranteed.

Q2. Designing a Secure Email System: PGP vs. S/MIME for a Corporate Environment

Aspect	PGP	S/MIME
Trust model	Decentralized web of trust	Centralized PKI / X.509 CA
Key management at scale	Manual key exchange, harder to audit	Automated via corporate CA/AD
Client support	Needs plug-ins (GPG, Enigmail, etc.)	Native in Outlook, Apple Mail, etc.
Best fit	Individuals, external/decentralized partners	Enterprises with existing PKI

Design choice: For a corporate environment with an existing Active Directory / internal CA, **S/MIME** is the better fit - it enables centralized certificate issuance, automatic renewal, and revocation, integrates natively with standard mail clients, and satisfies audit/compliance requirements more easily. **PGP** should be retained selectively for communication with external partners or open-source communities that do not participate in the corporate PKI, giving a hybrid design that uses each system where its trust model fits best.

Q3. Secure Email Transmission Workflow using Symmetric + Asymmetric Encryption

Design (sender side → receiver side):

1. Sender generates a random one-time **AES-256 session key**.
2. Message body is encrypted with this session key (fast, symmetric encryption for bulk data).
3. The session key itself is encrypted with the **recipient's RSA/ECC public key** (asymmetric encryption, used only for the small key, not the whole message).
4. Sender computes a hash (SHA-256) of the original message and signs it with their own **private key**, producing a digital signature for authenticity and non-repudiation.
5. The bundle - encrypted key + IV + ciphertext + signature - is transmitted as the email body/attachment.
6. Receiver decrypts the session key with their private key, decrypts the message with that session key, and verifies the signature using the sender's public key.

This workflow is exactly the construction used by PGP/OpenPGP and S/MIME: symmetric encryption gives speed for large message bodies, asymmetric encryption solves key-distribution without a shared secret, and the signature step adds authentication that pure encryption alone cannot provide.

Q4. Hybrid Spam Filtering Model (Rule-Based + Machine Learning)

Architecture:

Stage 1 - Rule-based pre-filter (fast, deterministic): checks sender reputation/blacklists, SPF/DKIM/DMARC authentication results, and simple keyword/regex heuristics. Emails that are obviously spam or obviously legitimate are decided here with very low latency.

Stage 2 - ML classifier (for uncertain cases): emails that the rule engine cannot confidently resolve are passed to a trained model (e.g. TF-IDF + Naive Bayes, or a Random Forest/SVM using richer features such as header anomalies, link count, and attachment type).

Stage 3 - Weighted ensemble scoring: rule-engine score and ML-model probability are combined into a single confidence score; emails above a spam threshold are quarantined, borderline ones are flagged for review.

Stage 4 - Feedback loop: user-reported false positives/negatives are fed back to retrain the ML component periodically, keeping the model current against evolving spam campaigns.

This hybrid design captures the best of both worlds: rule-based filters are transparent, auditable, and catch known bad senders instantly, while the ML layer generalizes to novel spam patterns that static rules would miss.

Q5. IPsec Transport vs. Tunnel Mode for Different Organizational Needs

Aspect	Transport Mode	Tunnel Mode
What is protected	Payload only; original IP header kept	Entire original IP packet
Overhead	Lower (no new IP header)	Higher (new outer IP header added)
Topology visibility	Internal IP addresses exposed	Internal topology hidden behind gateway
Typical deployment	Host-to-host, e.g. intra-datacenter traffic	Gateway-to-gateway site-to-site VPN, remote access VPN

Recommended configuration by organization type: A large enterprise with multiple branch offices connecting over the public internet should use **tunnel mode** at each site's VPN gateway - it hides internal addressing and protects the whole packet, which is essential when traffic crosses an untrusted network. A single data center securing east-west traffic between trusted internal hosts should prefer **transport mode** for its lower overhead, since topology hiding is unnecessary within a controlled network. Remote/home workers connecting into the corporate network should also use **tunnel mode** (client-to-gateway VPN), as their traffic traverses the public internet exactly like a site-to-site link.

Criteria	Weightage (%)	Level 4 (Exemplary)	Level 3 (Proficient)	Level 2 (Developing)	Level 1 (Beginning)
Scope of Items	20%	Selects highly relevant items with clear scope and justification	Selects appropriate items with minor gaps	Selection is limited or partially relevant	Items are unclear or not relevant
Comparison Depth	25%	Provides detailed and comprehensive comparison across multiple aspects	Provides adequate comparison with some depth	Limited comparison with few aspects	Very minimal or no comparison
Use of Evidence	20%	Supports comparison with accurate data, examples, or references	Uses some supporting evidence with minor gaps	Limited or weak supporting evidence	No supporting evidence provided
Critical Thinking	20%	Demonstrates strong critical thinking with clear interpretation and reasoning	Shows reasonable interpretation with minor gaps	Basic interpretation; lacks depth	No meaningful interpretation
Clarity of Presentation	15%	Well-organized, clear, and logically structured presentation	Generally clear with minor issues	Somewhat unclear or poorly structured	Disorganized and difficult to understand